

REPORT 3

Risk Assessment Data

Risk Item	Likelihood (1-5)	Impact (1-5)	Relative Risk Score (1-5)	Justification (IT Organization Context)	Primary Control Measures	Key Performance Indicator (KPI) / Key Risk Indicator (KRI)
Phishing	5 (High)	5 (Catastrophic)	5 (Extreme)	Primary attack vector leading to Ransomware/BEC. Directly impacts trust, finance, and business continuity.	Mandatory MFA on all accounts; Advanced email gateway filtering; Frequent, simulated phishing drills.	KRI: Phishing Click-Through Rate (Target: $<5\%$). KPI: MFA Coverage Rate (Target: 100% for privileged accounts).
Weak Password Sharing	4 (High)	4 (Major)	4 (Very High)	Leads to Account Takeover, loss of audit trail/accountability, and system configuration errors. Undermines basic security hygiene.	Enterprise Password Manager deployment; Formal policy against sharing; Quarterly privileged account audits.	KPI: Password Manager Adoption Rate (Target: $>95\%$). KRI: Shared Credential Violation Count (Target: <1 per month).
Unsanctioned Software (Shadow IT)	4 (High)	4 (Major)	4 (Very High)	Introduces unpatched vulnerabilities, potential malware, and leads to costly software license non-compliance fines/data leaks.	Application Whitelisting and EDR deployment; Clear "Acceptable Use Policy"; Formal review process for new tools.	KRI: Unidentified/Unapproved Applications Count (Target: Low, e.g., <10 per quarter). KPI: Asset Inventory Completeness (Target: $>98\%$).